

Mediroza General Hospital Black Box Penetration Testing Full Project Report

By Jeffrey Obi

Contents

Liability Disclaimer.....	2
Introduction.....	2
Objective.....	2
Phase 1: Initial Access.....	3
Situation.....	3
Task.....	3
Action.....	3
Result.....	7
Phase 2: Patient Files—Data Extraction and Cracking.....	7
Overview.....	7
Task.....	7
Action.....	7
Result.....	11
Phase 3: Staff & Shareholder Data Extraction.....	12
Situation.....	12
Task.....	12
Action.....	12
Result.....	15
Findings & Lessons Learned.....	15
Phase 4: Penetration Test Report.....	15
Executive Summary.....	15
Scope and Methodology.....	16
Findings & Proof of Exploitation.....	16
Risk Rating.....	20
Recommendations and Remediation.....	20

Black Box Penetration Testing

Liability Disclaimer

This project was undertaken for educational purposes **ONLY**. All activities were performed only on the device and network that I own, myself. This project was executed for education and research purposes **ONLY**. Written permission from the owner of the domain on which this penetration testing exercise was performed, was given.

Testing was limited to the target domain only. No social engineering, no denial of service, and no testing outside agreed scope was attempted.

Do not use anything from here to break the law. The instructor, the author and Networkwalks are not responsible for what you do with this knowledge. Every action you take is your own responsibility. Misuse can lead to criminal charges, heavy fines, loss of your job and a permanent record. In most countries unauthorized access is a crime, even when nothing is damaged.

Introduction

A black box penetration test is a simulated cyberattack where an ethical hacker evaluates a system with no prior knowledge of its internal architecture, source code, or design. The tester interacts with the target just like an outside attacker would, starting from scratch with only basic public details like a domain name or IP address.

Black-box tests start blind with only public information (like a URL or IP address). They simulate an external, unprivileged hacker attacking the perimeter. As opposed to **White-box** testing (where the tester begins with prior knowledge about the target), this test takes more time because testers must map the network and discover vulnerabilities manually. Black-box testing focuses on external behavior and visible entry points, which is why it is used to validate your public-facing perimeter and see how an external adversary reacts to your defenses.

This report covers a black-box test conducted on the Mediroza General Hospital domain (**medirozahospital.com**). In this project, I gained internal access to the domain, extracted sensitive files, cracked their encryptions, accessed the contents and produced a professional penetration test report.

Objective

Conduct a black-box test on Mediroza Hospital, starting with their website **<<https://medirozahospital.com>>**. This will be accomplished using the following structure:

- **Initial Access:** Retrieve 3 confidential patient PDF lab reports;
- **Data Extraction:** Crack the encryption on all 3 files;
- **Attack (Cracking):** Find staff salaries and hospital shareholder details; &
- **Reporting:** Gather findings and write a professional penetration testing report.

Phase 1: Initial Access

Situation

To begin the penetration test, the first phase needs to be cleared. This means reconnaissance via footprinting and scanning.

Task

Attack the website and gain access into the domain to retrieve **three** confidential patient PDF lab reports.

- Conduct reconnaissance on the target.
- Identify exposed entry points.
- Analyse the behaviour of any authentication mechanisms you find.
- Look for weaknesses in how the application handles user input.
- Gain unauthorised access to a restricted area of the site.

Action

1. Conduct reconnaissance on the domain **<medirozahospital.com>**
 - a. I ran footprinting commands from the Linux **Terminal**. These commands were **whois**, **whatweb**, **nslookup**, **curl -I**, **wafw00f**, **dnsrecon** & **theHarvester**. I also ran domain scans using **Maltego**.

```
kali@kali:~$ whois medirozahospital.com
Domain Name: MEDIROZAHOSPITAL.COM
Registry Domain ID: 319326963 DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.namecheap.com
Registrar URL: http://www.namecheap.com
Updated Date: 2026-08-14T21:07:45Z
Creation Date: 2026-08-14T20:51:24Z
Registry Expiry Date: 2027-08-14T20:51:24Z
Registrar: NameCheap, Inc.
Registrar IANA ID: 1868
Registrar Abuse Contact Email: abuse@namecheap.com
Registrar Abuse Contact Phone: +1.6613102107
Domain Status: clientTransferProhibited https://icann.org/eppdclientTransferProhibited
Name Server: DNS1.NAMECHEAPHOSTING.COM
Name Server: DNS2.NAMECHEAPHOSTING.COM
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-09-29T18:50:28Z <<<

For more information on Whois status codes, please visit https://icann.org/epp

NOTICE: The expiration date displayed in this record is the date the
registrar's sponsorship of the domain name registration in the registry is
currently set to expire. This date does not necessarily reflect the expiration
date of the domain name registrant's agreement with the sponsoring
registrar. Users may consult the sponsoring registrar's Whois database to
view the registrar's reported date of expiration for this registration.

TERMS OF USE: You are not authorized to access or query our Whois
database through the use of electronic processes that are high-volume and
```

whois

```
kali@kali:~$ whatweb medirozahospital.com
https://medirozahospital.com [403 Forbidden] Country[UNITED STATES][US], HTML5, HTTPServer[LiteSpeed], IP[199.188.201.16], LiteSpeed, PoweredBy[LiteSpeed], Title[403 Forbidden][Title element contains newline(s)], UncommonHeaders[x-turbo-charged-by]
http://medirozahospital.com [301 Moved Permanently] Country[UNITED STATES][US], HTML5, HTTPServer[LiteSpeed], IP[199.188.201.16], LiteSpeed, RedirectLocation[https://medirozahospital.com/], Title[301 Moved Permanently][Title element contains newline(s)], UncommonHeaders[x-turbo-charged-by]
https://medirozahospital.com/ [403 Forbidden] Country[UNITED STATES][US], HTML5, HTTPServer[LiteSpeed], IP[199.188.201.16], LiteSpeed, PoweredBy[LiteSpeed], Title[403 Forbidden][Title element contains newline(s)], UncommonHeaders[x-turbo-charged-by]
```

whatweb

```
kali@kali:~$ nslookup medirozahospital.com
Server:      8.8.8.8
Address:     8.8.8.8#53

Non-authoritative answer:
Name:   medirozahospital.com
Address: 199.188.201.16
```

nslookup

```

kali@kali:~$ curl -I medirozahospital.com
HTTP/1.1 200 OK
Server: openresty/1.31.1.1
Date: Tue, 29 Sep 2026 18:58:21 GMT
Connection: keep-alive
Content-Type: text/html
Cache-Control: private, no-cache, no-store, must-revalidate, max-age=0
cf-edge-cache: no-cache
    
```

curl -I

```

kali@kali:~$ wafw00f https://medirozahospital.com
[+] Checking https://medirozahospital.com
[+] The site https://medirozahospital.com is behind LiteSpeed (LiteSpeed Technologies) WAF.
[+] Number of requests: 2
    
```

wafw00f

```

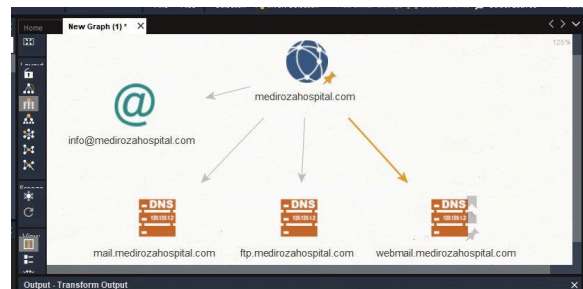
kali@kali:~$ theHarvester -d medirozahospital.com -l 50 -b all
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
theHarvester 4.11.1
* Coded by Christian Martorella
* Edge-Security Research
* cartorella@edge-security.com
*****
[*] Target: medirozahospital.com
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Failed to process bevigil search for word: 'medirozahospital.com'
Error Message:
    
```

theHarvester

```

kali@kali:~$ dnsrecon -d medirozahospital.com
2026-09-29T15:02:48.194278-0400 INFO Starting enumeration for domain: medirozahospital.com
2026-09-29T15:02:48.195303-0400 INFO std: Performing General Enumeration against: medirozahospital.com...
2026-09-29T15:02:50.496546-0400 ERROR No answer for DNSSEC query for medirozahospital.com
2026-09-29T15:02:50.699743-0400 INFO SOA dns1.namecheaphosting.com 156.154.132.200
2026-09-29T15:02:50.748052-0400 INFO SOA dns1.namecheaphosting.com 2610:al:1025::200
2026-09-29T15:02:51.045483-0400 INFO NS dns1.namecheaphosting.com 156.154.132.200
2026-09-29T15:02:51.179922-0400 INFO NS dns1.namecheaphosting.com 2610:al:1024::200
2026-09-29T15:02:51.282389-0400 INFO NS dns2.namecheaphosting.com 156.154.133.200
2026-09-29T15:02:51.408669-0400 INFO Bind Version for 156.154.132.200 Nameserver
2026-09-29T15:02:51.499122-0400 INFO NS dns2.namecheaphosting.com 2610:al:1025::200
2026-09-29T15:02:54.755984-0400 INFO A medirozahospital.com 199.188.201.16
2026-09-29T15:02:56.403220-0400 INFO TXT medirozahospital.com v=spf1 +a +mx +ip4:199.188.201.7 +ip4:199.188.201.079
2026-09-29T15:03:04.041228-0400 INFO SRV _carddav._tcp.medirozahospital.com medirozahospital.com 199.188.201.16 2070
2026-09-29T15:03:07.012295-0400 INFO SRV _cardavs._tcp.medirozahospital.com medirozahospital.com 199.188.201.16 2080
2026-09-29T15:03:07.258296-0400 INFO SRV _cardavs._tcp.medirozahospital.com medirozahospital.com 199.188.201.16 2080
2026-09-29T15:03:08.526167-0400 INFO 4 Records Found
2026-09-29T15:03:08.528016-0400 INFO Completed enumeration for domain: medirozahospital.com
    
```

dnsrecon



Maltego

b. Findings Include:

- i. **Domain Name Servers:** DNS1.NAMECHEAPHOSTING.COM; DNS2.NAMECHEAPHOSTING.COM
- ii. **Location:** Lewes, Delaware, USA. Post Code: 19958.
- iii. **Web Server IP:** 199.188.201.16
- iv. **Web Server Application:** LiteSpeed
- v. **ASN:** 22612
- vi. **Reverse Proxy:** OpenResty/1.31.1.1
- vii. **Web Application Firewalls:** LiteSpeed (LiteSpeed Technologies) WAF
- viii. **Domain Statistics:**
 - **3 IPs found:** 199.188.201.16
 - **1 email found:** info@medirozahospital.com
 - **3 hosts:** ftp.medirozahospital.com • mail.medirozahospital.com • webmail.medirozahospital.com
 - 0 total compromised, 0 employees, 0 users, 0 stealers

c. Inspect the robots.txt file which outlines instructions for external crawlers.

```

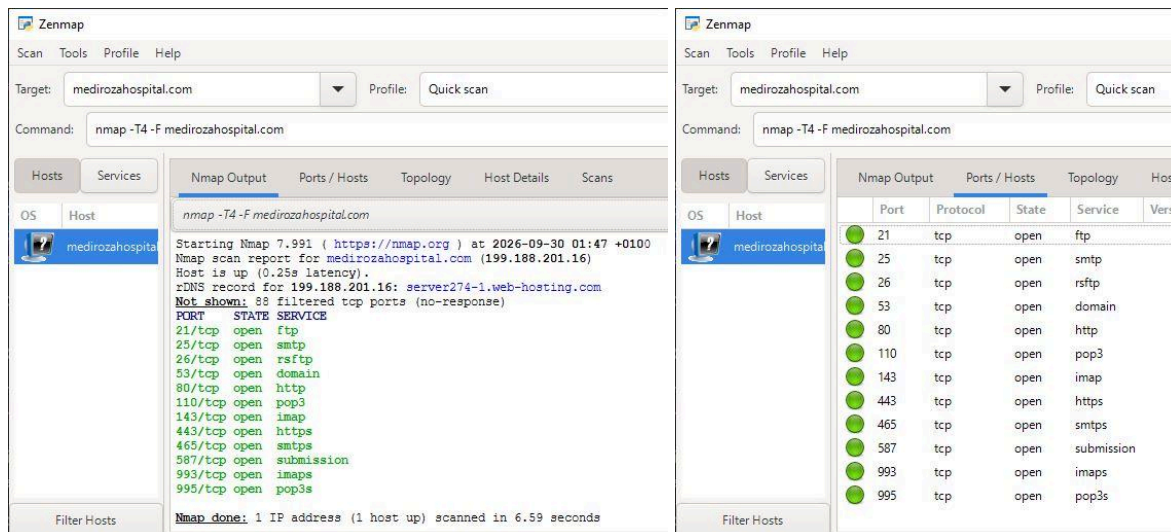
medirozahospital.com/robots.txt

# robots.txt
User-agent: *
Disallow: /patient/
Disallow: /staff/
Disallow: /old/

Sitemap: https://medirozahospital.com/sitemap.xml
    
```

Contents of the robots.txt file revealing hidden internal server directories

- i. The internal directories revealed by the robots.txt file are:
 - /patient/
 - /staff/
 - /old/
2. Identify exposed entry points.
 - a. Scan the domain using Zenmap.



Zenmap scan results

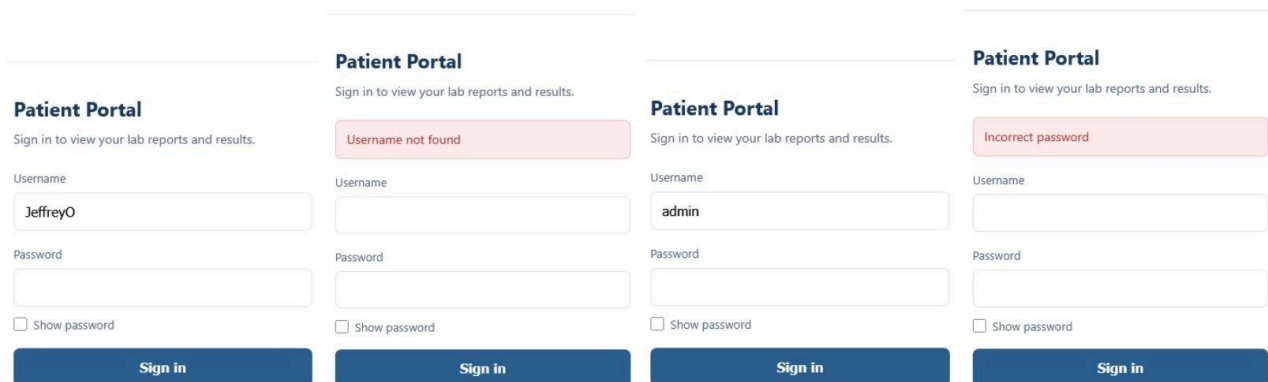
- b. Findings reveal the following ports are open on 199.188.201.16:
 - i. 21/tcp open ftp (unsecure)
 - ii. 25/tcp open smtp (unsecure)
 - iii. 26/tcp open rsftp (potentially unsecure)
 - iv. 53/tcp open domain (potentially unsecure)
 - v. 80/tcp open http (unsecure)
 - vi. 110/tcp open pop3 (unsecure)
 - vii. 143/tcp open imap (unsecure)
 - viii. 443/tcp open https
 - ix. 465/tcp open smtps
 - x. 587/tcp open submission
 - xi. 993/tcp open imaps
 - xii. 995/tcp open pop3s
- c. The exposed entry points (unsecure ports) are:
 - i. FTP
 - ii. SMTP
 - iii. HTTP
 - iv. POP3
 - v. IMAP

This reveals that the file server access port (**FTP**) is unsecure, providing a potential access point for extracting sensitive files.

3. Analyse authentication mechanisms.
 - a. After intentionally trying to login with an unlikely username, e.g., my name, "**JeffreyObi**" and leaving the password box empty, the login form returned the error message: "**Username not found,**" exposing 2 security flaws: **improper input**

validation (where a form allows the submission of incomplete queries) and **account enumeration** (where a system explicitly tells an attacker whether or not a username exists, inside the error message, revealing valuable architectural data that can be exploited).

- b. While trying some common usernames, I tried “**admin**” and it returned the error message “**Incorrect password**” which indicates that while the password is wrong/missing, the username is valid.



The image displays four sequential screenshots of the 'Patient Portal' login interface. Each screenshot shows a form with 'Username' and 'Password' fields, a 'Show password' checkbox, and a 'Sign in' button. The first screenshot shows a successful login with 'JeffreyO'. The second screenshot shows an error message 'Username not found' for an empty username field. The third screenshot shows an error message 'Incorrect password' for the username 'admin'. The fourth screenshot shows the same 'Incorrect password' message for an empty password field.

Screenshots of the Mediroza General Hospital patient login portal revealing account enumeration and improper input validation.

4. Access the unsecure file server.

- a. I explored an SQL injection attack by first checking for input sanitization.
 - i. I submitted a login request with only a quotation mark (') in the **Username** field.
 - ii. The form returned the following error message, indicating a vulnerability in which the input is being joined directly into a database command string:
Warning: mysqli_query(): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near ''' at line 1
- b. This exposed the lack of input sanitization means a well-crafted SQL injection might work. I submitted a login request with the username “**admin'--**” and an empty password field, and I was granted access to a private page containing links to three patient “Pathology reports.”

Screenshots revealing SQL vulnerability and a successful injection attack

Result

The task is now complete. Using SQL injection, I successfully gained access to patient reports

Phase 2: Patient Files—Data Extraction and Cracking

Data extraction involved the extraction of protected data and subsequent password cracking. Cracking involved breaking through the encryption on the files to access their internal contents. After gaining initial access to the domain, the artifacts are collected for further penetration within the scope of the penetration test.

Overview

After I gained special access to the domain by infiltrating the authentication system, the next activity was the extraction and collection of PDF files. After that, the files were cracked. On opening each file, all three files revealed to be encrypted. I passed the PDF files through hash extractor and password cracking tools in order to crack their encryptions and access the files' contents, all within the scope of the penetration test.

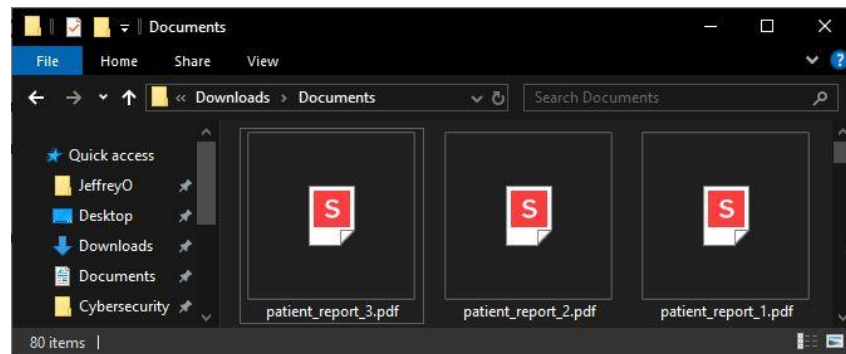
Task

Acquire the three PDF patient reports (**patient_report_1.pdf**, **patient_report_2.pdf** & **patient_report_3.pdf**) and crack their passwords using chosen and capable tools.

Action

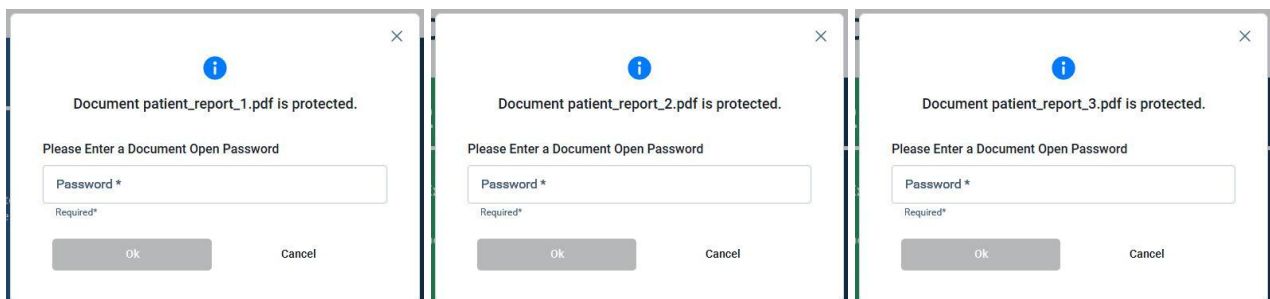
1. Download the three 'Pathology Report' files

- a. Click the three '**Download**' buttons to download the corresponding report files.



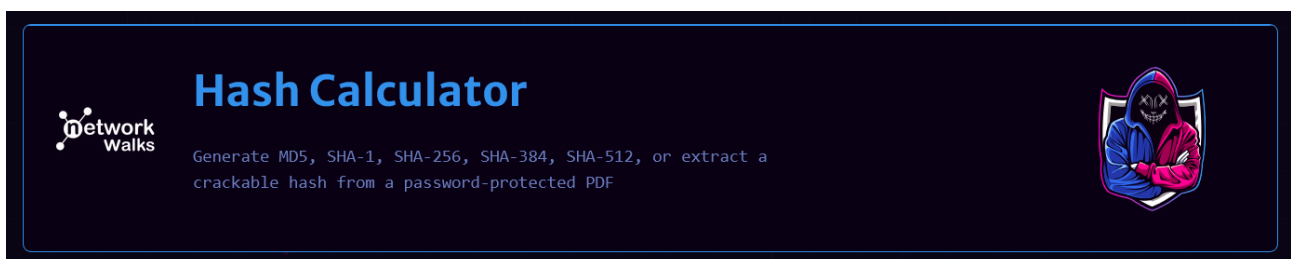
Screenshot of the **File Explorer** window showing the downloaded PDF reports.

2. On opening, the three PDF files revealed to be password protected.



Screenshots showing the three password prompts when opening the PDF files.

3. Extract the PDF password hashes.
 - a. Open Network Walks' **Hash Calculator** in the web browser using the URL:
<https://networkwalks.com/hash-calculator/>



- b. For each PDF file: select the **PDF** tab and click the padlock icon to upload the file. Select the extracted PDF file and copy out the extracted hash.

patient_report_1.pdf | 3.6 KB

This PDF is encrypted. A crackable hash has been extracted below (pdf2john / hashcat compatible format).

PDF Hash

```
$pdf$2*3*128*4294967292*1*32*3361663365326235643333353531613238303137316238333  
238373763353339*32*ef16c52ab8efce2c18c79e9d28895b5928bf4e5e4e758a4164004e56fff  
a0108*32*c431fab9cc5ef7b59c244b61b745f71ac5ba427b1b9102da468e77127f1e69d6
```

Copy

Download

patient_report_2.pdf | 3.5 KB

This PDF is encrypted. A crackable hash has been extracted below (pdf2john / hashcat compatible format).

PDF Hash

```
$pdf$2*3*128*4294967292*1*32*3166346338373236356437626464363834663737303265633  
666363264616463*32*39f4e6b0aef12344c340ffb39f8905528bf4e5e4e758a4164004e56fff  
a0108*32*408b37bcf12da873d7f2840f3c1b917a023961ded4c8164d38e46e9655e66775
```

Copy

Download

patient_report_3.pdf | 3.6 KB

This PDF is encrypted. A crackable hash has been extracted below (pdf2john / hashcat compatible format).

PDF Hash

```
$pdf$2*3*128*4294967292*1*32*3261393066326130336634386337323631306164373264323  
130316137616538*32*5090fa0a5dba99cb97c9d140cd23119428bf4e5e4e758a4164004e56fff  
a0108*32*58e03d692cf37b50b0b5eaa189fcbd372260a949c8992ad7b44fd13e2b40c1f8
```

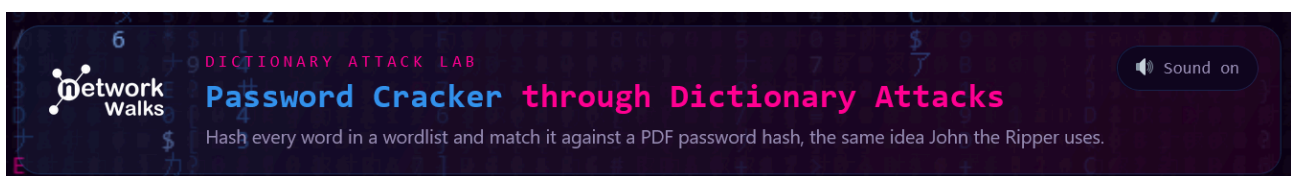
Copy

Download

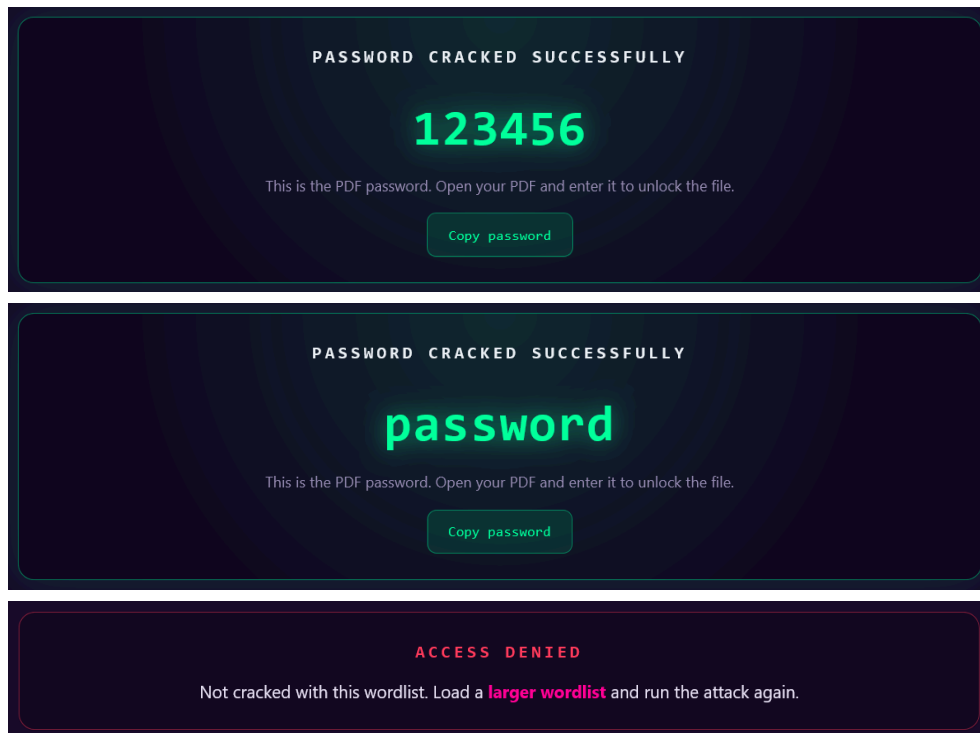
Screenshots of the **Hash Calculator** interfaces showing the extracted hashes of the three PDF files.

4. Crack the PDF passwords using their hashes.

- a. Open Network Walks' **Password Cracker** in the web browser using the URL:
<https://networkwalks.com/password-cracker/>

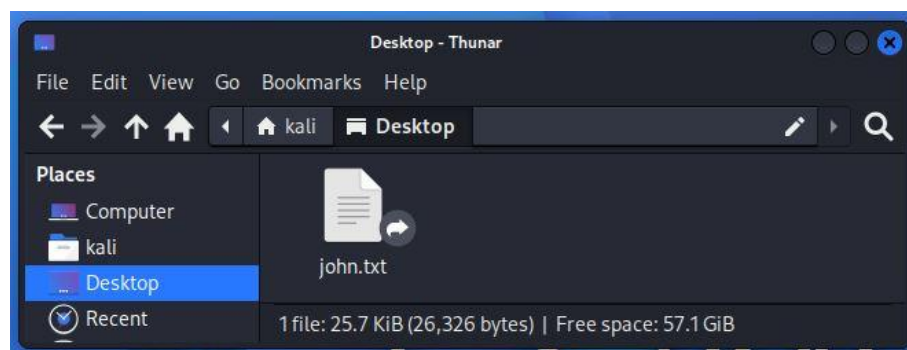


- b. For the first and second PDF files: paste the extracted password hash in the **PDF Hash** box and click **Start Cracking**. After the cracking process completes, a password appears on the interface. Copy out the password.

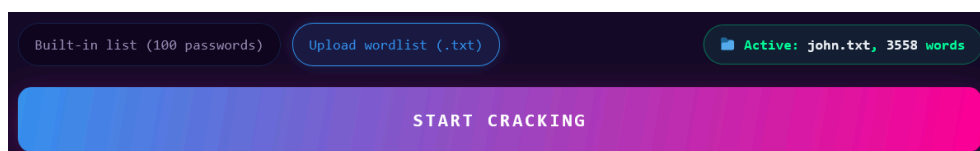


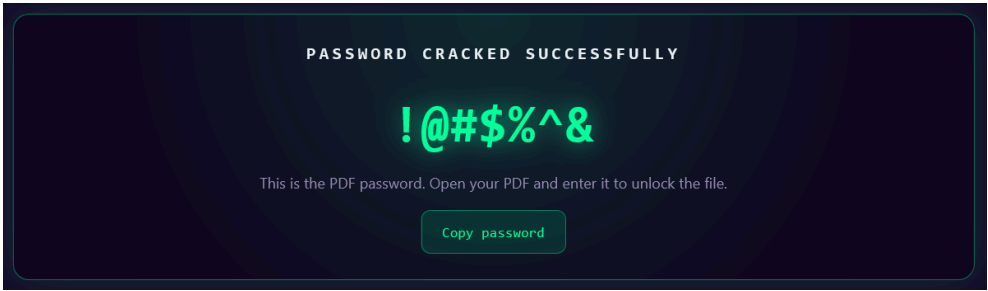
Screenshots of the **Password Cracker** interfaces showing the cracked passwords of the first two PDF files and the failed attempt of the third file due to the insufficient wordlist.

- c. For the third file, I located another wordlist file (john.lst) from the **wordlists** folder on Kali Linux. I extracted its contents into a new **john.txt** file on the Desktop.



- d. I loaded the wordlist file on the **Password Cracker** tool by clicking the **Upload wordlist (.txt)** button and selecting it. Then I clicked the **Start Cracking** button. After the cracking process completed, the password appeared and I copied it out.





Screenshots showing the loaded wordlists file and the cracked password.

- e. Open each PDF file and apply the corresponding password discovered from the cracking step to access the files' contents.

Mediroza

General Hospital

14 Cedar Avenue, Johannesburg, South Africa

Tel: +27 11 555 0100

medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name:

Sipho Dlamini

Patient ID:

MG-P-10231

Date of Birth:

1984-06-12

Gender:

Male

Report Date:

2024-11-04

Referring Dr:

Dr. Anita Naicker

Specimen:

Whole blood (EDTA)

Lab Ref No:

LR-2024-1187

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	13.9	g/dL	13.0 - 17.0	Normal
White Cell Count	11.8	x10 ⁹ /L	4.0 - 11.0	HIGH
Platelet Count	245	x10 ⁹ /L	150 - 400	Normal
Fasting Glucose	5.4	mmol/L	3.9 - 5.5	Normal
Creatinine	88	umol/L	64 - 104	Normal

Mediroza

General Hospital

14 Cedar Avenue, Johannesburg, South Africa

Tel: +27 11 555 0100

medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name:

Priya Reddy

Patient ID:

MG-P-10244

Date of Birth:

1991-02-28

Gender:

Female

Report Date:

2024-11-05

Referring Dr:

Dr. Johan van der Merwe

Specimen:

Serum

Lab Ref No:

LR-2024-1192

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Total Cholesterol	6.4	mmol/L	< 5.0	HIGH
LDL Cholesterol	4.1	mmol/L	< 3.0	HIGH
HDL Cholesterol	1.2	mmol/L	> 1.0	Normal
Triglycerides	1.8	mmol/L	< 1.7	HIGH
Fasting Glucose	4.9	mmol/L	3.9 - 5.5	Normal

Mediroza

General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name:

Emily Thompson

Patient ID:

MG-P-10258

Date of Birth:

1978-09-03

Gender:

Female

Report Date:

2024-11-06

Referring Dr:

Dr. Ahmed Kara

Specimen:

Serum

Lab Ref No:

LR-2024-1205

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	11.4	g/dL	12.0 - 15.5	LOW
Ferritin	9	ug/L	15 - 150	LOW
TSH	3.1	mIU/L	0.4 - 4.0	Normal
Vitamin D	42	nmol/L	50 - 125	LOW
Fasting Glucose	5.1	mmol/L	3.9 - 5.5	Normal

Screenshots showing the contents of the three PDF files.

Result

The task is now complete. I successfully accessed each of the three PDFpatient report files after collecting them, extracting their hashes and cracking their passwords, all within the required scope.

Phase 3: Staff & Shareholder Data Extraction

Situation

The staff salaries and shareholder details need to be found.

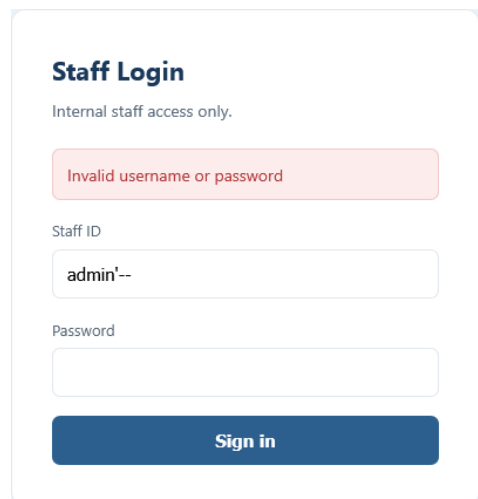
Task

Find the following data:

- Salaries of all hospital employees, &
- Shareholder details of the hospital.

Action

1. Explore SQL injection on the staff login portal.
 - a. Visit the staff login portal (medirozahospital.com/staff/login.php).
 - b. Perform an SQL injection by submitting a login request with “**admin'--**” in the username box and the password box empty.
 - c. The error message “**Invalid username or password**” was returned, indicating proper SQL configuration, input validation and input sanitization. A marked improvement on the patient login portal.
2. Explore hidden paths.
 - a. From the robots.txt earlier, explore the accessible and relevant paths for any data.
 - b. Visit medirozahospital.com/staff and medirozahospital.com/old



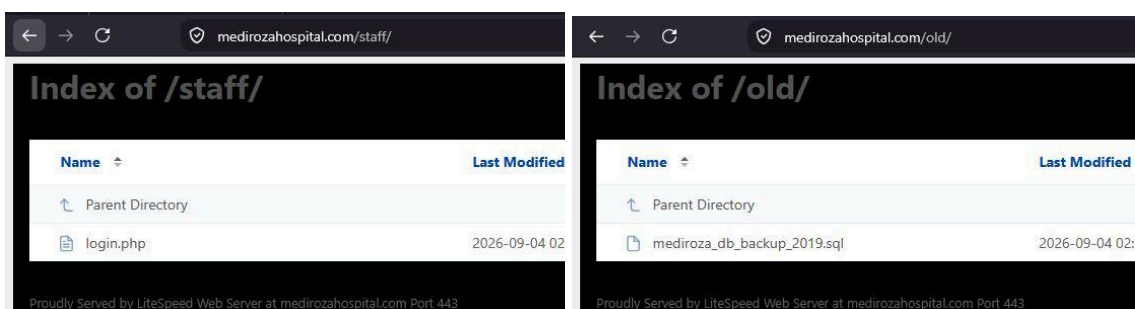
Staff Login
Internal staff access only.

Invalid username or password

Staff ID
admin'--

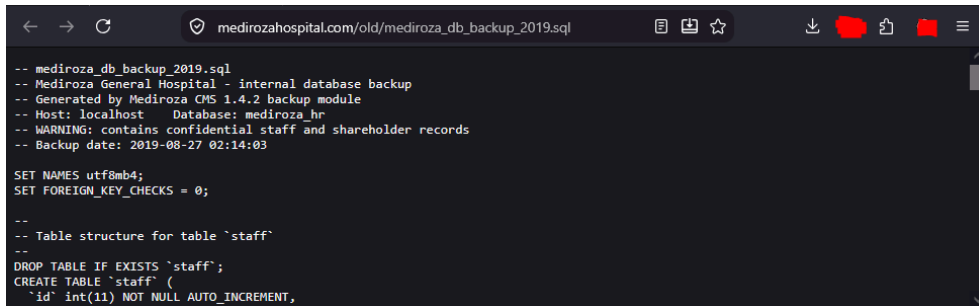
Password

Sign in



Screenshots of the hidden directories.

- c. The “staff” path only contains a page file which appears to be the staff login portal (**login.php**). The “old” path contains an SQL database file (**mediroza_db_backup_2019.sql**). I clicked it, revealing its contents in the browser.



```
-- mediroza_db_backup_2019.sql
-- Mediroza General Hospital - internal database backup
-- Generated by Mediroza CMS 1.4.2 backup module
-- Host: localhost    Database: mediroza_hr
-- WARNING: contains confidential staff and shareholder records
-- Backup date: 2019-08-27 02:14:03

SET NAMES utf8mb4;
SET FOREIGN_KEY_CHECKS = 0;

--
-- Table structure for table `staff`
--
DROP TABLE IF EXISTS `staff`;
CREATE TABLE `staff` (
  `id` int(11) NOT NULL AUTO_INCREMENT,
```

*Screenshot of the **mediroza_db_backup_2019** SQL file.*

3. Inspect the **mediroza_db_backup_2019.sql** file for required data.

a. Staff Salaries:

- | | |
|---|---------------------------------|
| i. Dr. Rajesh Naidoo: 138000 | xv. Kagiso Sithole: 61000, |
| ii. Sarah Botha: 152000 | xvi. Naledi Zulu: 26000 |
| iii. Dr. Johan van der Merwe:
160000 | xvii. Themba Nkosi: 44000 |
| iv. Dr. Anita Naicker: 132000 | xviii. Palesa Radebe: 43000 |
| v. Dr. Ahmed Kara: 128000 | xix. Deepak Pillay: 41000 |
| vi. Dr. Yusuf Cassim: 74000 | xx. Kavitha Govender: 35000 |
| vii. Michael Roberts: 96000 | xxi. Dr. Suresh Moodley: 130000 |
| viii. Susan Pretorius: 32000 | xxii. Dr. Fatima Patel: 118000 |
| ix. Jameel Malik: 58000 | xxiii. Nisha Singh: 48000 |
| x. Thabo Molefe: 46000 | xxiv. Dr. Vikram Chetty: 135000 |
| xi. Nomvula Khumalo: 34000 | xxv. David Smith: 52000 |
| xii. Lerato Mokoena: 33000 | xxvi. Karen O"Conno: 29000 |
| xiii. Bongani Ndlovu: 35000 | xxvii. James Wilson: 27000 |
| xiv. Zanele Mahlangu: 42000 | xxviii. Linda Fourie: 19000 |
| | xxix. Peter van Wyk: 38000 |
| | xxx. Andile Mbeki: 21000 |

```
LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`,`full name`,`job title`,`department`,`email`,`phone`,`national id`,`monthly salary zar`,`date joined`) VALUES
(1,'Dr. Rajesh Naidoo','Chief Pathologist','Diagnostics Lab','r.naidoo@medirozahospital.com','+27 82 101 2007','85021013011081',138000,'2009-03-16'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','85031023022082',152000,'2011-07-01'),
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.merwe@medirozahospital.com','+27 82 103 2021','85041033033083',160000,'2007-01-22'),
(4,'Dr. Anita Naicker','Consultant Cardiologist','Cardiology','a.naicker@medirozahospital.com','+27 82 104 2028','85051043044084',132000,'2012-09-10'),
(5,'Dr. Ahmed Kara','Consultant Physician','Internal Medicine','a.kara@medirozahospital.com','+27 82 105 2035','85061053055085',128000,'2013-02-18'),
(6,'Dr. Yusuf Cassim','Senior Registrar','Emergency & Trauma','y.cassim@medirozahospital.com','+27 82 106 2042','85071063066086',74000,'2018-05-04'),
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 107 2049','85081073077087',96000,'2010-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2056','85091083088088',32000,'2016-08-23'),
(9,'Jameel Malik','IT Systems Administrator','IT','j.malik@medirozahospital.com','+27 82 109 2063','85101093099089',58000,'2015-04-12'),
(10,'Thabo Molefe','Network Engineer','IT','t.molefe@medirozahospital.com','+27 82 110 2070','85111103110081',46000,'2017-10-02'),
(11,'Nomvula Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2077','85121113121082',34000,'2016-01-19'),
(12,'Lerato Mokoena','Registered Nurse','Pediatrics','l.mokoena@medirozahospital.com','+27 82 112 2084','85011123132083',33000,'2017-06-07'),
(13,'Bongani Ndlovu','Registered Nurse','Cardiology','b.ndlovu@medirozahospital.com','+27 82 113 2091','85021133143084',35000,'2015-12-01'),
(14,'Zanele Mahlangu','Nursing Sister','Theatre','z.mahlangu@medirozahospital.com','+27 82 114 2098','85031143154085',42000,'2013-03-25'),
(15,'Kagiso Sithole','Pharmacist','Pharmacy','k.sithole@medirozahospital.com','+27 82 115 2105','85041153165086',61000,'2014-09-08'),
(16,'Naledi Zulu','Pharmacy Assistant','Pharmacy','n.zulu@medirozahospital.com','+27 82 116 2112','85051163176087',26000,'2019-02-14'),
(17,'Themba Nkosi','Radiographer','Radiology','t.nkosi@medirozahospital.com','+27 82 117 2119','85061173187088',44000,'2016-07-30'),
(18,'Palesa Radebe','Radiographer','Radiology','p.radebe@medirozahospital.com','+27 82 118 2126','85071183198089',43000,'2017-04-11'),
(19,'Deepak Pillay','Lab Technologist','Diagnostics Lab','d.pillay@medirozahospital.com','+27 82 119 2133','85081193209081',41000,'2015-05-20'),
(20,'Kavitha Govender','Lab Technician','Diagnostics Lab','k.govender@medirozahospital.com','+27 82 120 2140','85091203220082',35000,'2018-08-06'),
(21,'Dr. Suresh Moodley','Consultant Radiologist','Radiology','s.moodley@medirozahospital.com','+27 82 121 2147','85101213231083',130000,'2012-02-28'),
(22,'Dr. Fatima Patel','Pediatrician','Pediatrics','f.patel@medirozahospital.com','+27 82 122 2154','85111223242084',118000,'2013-10-17'),
(23,'Nisha Singh','Physiotherapist','Rehabilitation','n.singh@medirozahospital.com','+27 82 123 2161','85121233253085',48000,'2016-11-09'),
(24,'Dr. Vikram Chetty','Anaesthetist','Theatre','v.chetty@medirozahospital.com','+27 82 124 2168','85011243264086',135000,'2011-06-13'),
(25,'David Smith','Facilities Manager','Operations','d.smith@medirozahospital.com','+27 82 125 2175','85021253275087',52000,'2014-01-27'),
(26,'Karen O'Connor','Billing Administrator','Finance','k.oconnor@medirozahospital.com','+27 82 126 2182','85031263286088',29000,'2018-03-19'),
(27,'James Wilson','Security Supervisor','Operations','j.wilson@medirozahospital.com','+27 82 127 2189','85041273297089',27000,'2019-09-02'),
(28,'Linda Fourie','Receptionist','Front Office','l.fourie@medirozahospital.com','+27 82 128 2196','85051283308081',19000,'2020-02-10'),
(29,'Peter van Wyk','Procurement Officer','Supply Chain','p.wyk@medirozahospital.com','+27 82 129 2203','85061293319082',38000,'2015-08-24'),
(30,'Andile Mbeki','Ward Clerk','Administration','a.mbeki@medirozahospital.com','+27 82 130 2210','85071303330083',21000,'2019-11-05');
UNLOCK TABLES;
```

Screenshot of the SQL file showing staff details, including salaries.

b. Shareholder details:

ID	Shareholder Name	Share Percent (%)	Shares Held	Share Class
1	Dr. Rajesh Naidoo	18.0	180,000	Ordinary
2	Cedar Health Holdings (Pty) Ltd	15.0	150,000	Ordinary
3	Dr. Johan van der Merwe	12.0	120,000	Ordinary
4	Reddy Family Trust	11.0	110,000	Ordinary
5	Thabo Molefe	10.0	100,000	Ordinary
6	Sarah Botha	9.0	90,000	Ordinary
7	Dr. Ahmed Kara	8.0	80,000	Preferential
8	Naledi Zulu	7.0	70,000	Ordinary
9	Michael Roberts	6.0	60,000	Ordinary
10	Dr. Vikram Chetty	4.0	40,000	Preferential

```
LOCK TABLES `shareholders` WRITE;
INSERT INTO `shareholders`
(`id`,`shareholder_name`,`share_percent`,`shares_held`,`share_class`) VALUES
(1,'Dr. Rajesh Naidoo',18.0,180000,'Ordinary'),
(2,'Cedar Health Holdings (Pty) Ltd',15.0,150000,'Ordinary'),
(3,'Dr. Johan van der Merwe',12.0,120000,'Ordinary'),
(4,'Reddy Family Trust',11.0,110000,'Ordinary'),
(5,'Thabo Molefe',10.0,100000,'Ordinary'),
(6,'Sarah Botha',9.0,90000,'Ordinary'),
(7,'Dr. Ahmed Kara',8.0,80000,'Preferential'),
(8,'Naledi Zulu',7.0,70000,'Ordinary'),
(9,'Michael Roberts',6.0,60000,'Ordinary'),
(10,'Dr. Vikram Chetty',4.0,40000,'Preferential');
UNLOCK TABLES;
```

Screenshot of the SQL file showing shareholder details.

Result

The task is now complete. I successfully reached and opened the exposed SQL database file to access the requested sensitive data: staff and shareholder information.

Findings & Lessons Learned

I found the following conditions and vulnerabilities in the domain:

1. Unsecure ports exposed;
2. Absent input validation on patient login portals;
3. Absent input sanitization on patient login portals;
4. Domain crawler instructions enumerate hidden directories;
5. Hidden “old” directory contains a retained unencrypted database file holding sensitive information;
6. The staff login portal appears to have proper input validation and input sanitization.

The above findings reinforce the following web application best practices:

1. Only the ports for encryption-secured protocols should be open.
2. Web frontend and backend should be configured with input validation and input sanitation.
3. Implement alternatives to a robots.txt file which don't enumerate hidden/restricted paths.
Examples include adding a **X-Robots-Tag** in the HTTP response header, or adding a HTML Meta Tag to the specific page/path you want restricted.
4. Sensitive and retained database files should be encrypted.

Phase 4: Penetration Test Report

Executive Summary

A black-box penetration test is a security examination carried out by an ethical hacker. It involves simulating the conditions and activities of an external attacker with the intention of understanding the target's vulnerabilities. This examination was conducted on the Mediroza General Hospital

domain (**medirozahospital.com**) with written permission from the owner. The test proved successful, as weaknesses were discovered on the domain and sensitive data was accessed.

Scope and Methodology

Target

The target was the Mediroza General Hospital domain (**medirozahospital.com**).

Tools

Tools used include:

1. Machine: Lenovo Thinkpad
2. Operating System: Windows
3. Operating System: Kali Linux
4. Linux Tools: whois, whatweb, nslookup, curl, wafw00f, DNSrecon, & theHarvester.
5. OSINT tool: Maltego
6. Domain Scanner: Zenmap
7. Browser: Firefox
8. PDF Password Hash Extractor: Networkwalk's Hash Calculator
9. PDF Password Cracker: Networkwalk's Password Cracker

Approach

The systemic approach employed for the test involved the following procedure:

1. Reconnaissance
2. Scanning
3. Gaining access
4. Extraction
5. Cracking

Limitations

I encountered the following limitations while undertaking this project:

1. Inconsistent security configurations across login portals.
2. Inconsistent permissions for accessible files and directories within hidden paths.
3. Backend system defended against brute-force attacks.

Findings & Proof of Exploitation

As proof of exploitation, the following data was found from the black-box penetration test.

1. Patient Reports

a. Pathology Report - S. Dlamini

**Mediroza**
General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT**CONFIDENTIAL**

Patient Name:**Sipho Dlamini**

Patient ID:**MG-P-10231**

Date of Birth:**1984-06-12**

Gender:**Male**

Report Date:**2024-11-04**

Referring Dr:**Dr. Anita Naicker**

Specimen:**Whole blood (EDTA)**

Lab Ref No:**LR-2024-1187**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	13.9	g/dL	13.0 - 17.0	Normal
White Cell Count	11.8	x10 ⁹ /L	4.0 - 11.0	HIGH
Platelet Count	245	x10 ⁹ /L	150 - 400	Normal
Fasting Glucose	5.4	mmol/L	3.9 - 5.5	Normal
Creatinine	88	umol/L	64 - 104	Normal

Screenshot of the **patient_report_1.pdf** file showing its contents.

b. Pathology Report - P. Reddy

**Mediroza**
General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT**CONFIDENTIAL**

Patient Name:**Priya Reddy**

Patient ID:**MG-P-10244**

Date of Birth:**1991-02-28**

Gender:**Female**

Report Date:**2024-11-05**

Referring Dr:**Dr. Johan van der Merwe**

Specimen:**Serum**

Lab Ref No:**LR-2024-1192**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Total Cholesterol	6.4	mmol/L	< 5.0	HIGH
LDL Cholesterol	4.1	mmol/L	< 3.0	HIGH
HDL Cholesterol	1.2	mmol/L	> 1.0	Normal
Triglycerides	1.8	mmol/L	< 1.7	HIGH
Fasting Glucose	4.9	mmol/L	3.9 - 5.5	Normal

Screenshot of the **patient_report_2.pdf** file showing its contents.

c. Pathology Report - E. Thompson



14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name: **Emily Thompson** Report Date: **2024-11-06**
Patient ID: **MG-P-10258** Referring Dr: **Dr. Ahmed Kara**
Date of Birth: **1978-09-03** Specimen: **Serum**
Gender: **Female** Lab Ref No: **LR-2024-1205**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	11.4	g/dL	12.0 - 15.5	LOW
Ferritin	9	ug/L	15 - 150	LOW
TSH	3.1	mIU/L	0.4 - 4.0	Normal
Vitamin D	42	nmol/L	50 - 125	LOW
Fasting Glucose	5.1	mmol/L	3.9 - 5.5	Normal

Screenshot of the **patient_report_3.pdf** file showing its contents.

2. Staff and shareholder details

a. Staff Salaries (in Rand):

- | | |
|--------------------------------------|---------------------------------|
| i. Dr. Rajesh Naidoo: 138000 | xvi. Naledi Zulu: 26000 |
| ii. Sarah Botha: 152000 | xvii. Themba Nkosi: 44000 |
| iii. Dr. Johan van der Merwe: 160000 | xviii. Palesa Radebe: 43000 |
| iv. Dr. Anita Naicker: 132000 | xix. Deepak Pillay: 41000 |
| v. Dr. Ahmed Kara: 128000 | xx. Kavitha Govender: 35000 |
| vi. Dr. Yusuf Cassim: 74000 | xxi. Dr. Suresh Moodley: 130000 |
| vii. Michael Roberts: 96000 | xxii. Dr. Fatima Patel: 118000 |
| viii. Susan Pretorius: 32000 | xxiii. Nisha Singh: 48000 |
| ix. Jameel Malik: 58000 | xxiv. Dr. Vikram Chetty: 135000 |
| x. Thabo Molefe: 46000 | xxv. David Smith: 52000 |
| xi. Nomvula Khumalo: 34000 | xxvi. Karen O'Conno: 29000 |
| xii. Lerato Mokoena: 33000 | xxvii. James Wilson: 27000 |
| xiii. Bongani Ndlovu: 35000 | xxviii. Linda Fourie: 19000 |
| xiv. Zanele Mahlangu: 42000 | xxix. Peter van Wyk: 38000 |
| xv. Kagiso Sithole: 61000, | xxx. Andile Mbeki: 21000 |

```
LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`,`full name`,`job title`,`department`,`email`,`phone`,`national id`,`monthly salary zar`,`date joined`) VALUES
(1,'Dr. Rajesh Naidoo','Chief Pathologist','Diagnostics Lab','r.naidoo@medirozahospital.com','+27 82 101 2007','85021013011081',138000,'2009-03-16'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','85031023022082',152000,'2011-07-01'),
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.merwe@medirozahospital.com','+27 82 103 2021','85041033033083',160000,'2007-01-22'),
(4,'Dr. Anita Naicker','Consultant Cardiologist','Cardiology','a.naicker@medirozahospital.com','+27 82 104 2028','85051043044084',132000,'2012-09-10'),
(5,'Dr. Ahmed Kara','Consultant Physician','Internal Medicine','a.kara@medirozahospital.com','+27 82 105 2035','85061053055085',128000,'2013-02-18'),
(6,'Dr. Yusuf Cassim','Senior Registrar','Emergency & Trauma','y.cassim@medirozahospital.com','+27 82 106 2042','85071063066086',74000,'2018-05-04'),
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 107 2049','85081073077087',96000,'2010-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2056','85091083088088',32000,'2016-08-23'),
(9,'Jameel Malik','IT Systems Administrator','IT','j.malik@medirozahospital.com','+27 82 109 2063','85101093099089',58000,'2015-04-12'),
(10,'Thabo Molefe','Network Engineer','IT','t.molefe@medirozahospital.com','+27 82 110 2070','85111103110081',46000,'2017-10-02'),
(11,'Nomvula Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2077','85121113121082',34000,'2016-01-19'),
(12,'Lerato Mokoena','Registered Nurse','Pediatrics','l.mokoena@medirozahospital.com','+27 82 112 2084','85011123132083',33000,'2017-06-07'),
(13,'Bongani Ndlovu','Registered Nurse','Cardiology','b.ndlovu@medirozahospital.com','+27 82 113 2091','85021133143084',35000,'2015-12-01'),
(14,'Zanele Mahlangu','Nursing Sister','Theatre','z.mahlangu@medirozahospital.com','+27 82 114 2098','85031143154085',42000,'2013-03-25'),
(15,'Kagiso Sithole','Pharmacist','Pharmacy','k.sithole@medirozahospital.com','+27 82 115 2105','85041153165086',61000,'2014-09-08'),
(16,'Naledi Zulu','Pharmacy Assistant','Pharmacy','n.zulu@medirozahospital.com','+27 82 116 2112','85051163176087',26000,'2019-02-14'),
(17,'Themba Nkosi','Radiographer','Radiology','t.nkosi@medirozahospital.com','+27 82 117 2119','85061173187088',44000,'2016-07-30'),
(18,'Palesa Radebe','Radiographer','Radiology','p.radebe@medirozahospital.com','+27 82 118 2126','85071183198089',43000,'2017-04-11'),
(19,'Deepak Pillay','Lab Technologist','Diagnostics Lab','d.pillay@medirozahospital.com','+27 82 119 2133','85081193209081',41000,'2015-05-20'),
(20,'Kavitha Govender','Lab Technician','Diagnostics Lab','k.govender@medirozahospital.com','+27 82 120 2140','85091203220082',35000,'2018-08-06'),
(21,'Dr. Suresh Moodley','Consultant Radiologist','Radiology','s.moodley@medirozahospital.com','+27 82 121 2147','85101213231083',130000,'2012-02-28'),
(22,'Dr. Fatima Patel','Pediatrician','Pediatrics','f.patel@medirozahospital.com','+27 82 122 2154','85111223242084',118000,'2013-10-17'),
(23,'Nisha Singh','Physiotherapist','Rehabilitation','n.singh@medirozahospital.com','+27 82 123 2161','85121233253085',48000,'2016-11-09'),
(24,'Dr. Vikram Chetty','Anaesthetist','Theatre','v.chetty@medirozahospital.com','+27 82 124 2168','85011243264086',135000,'2011-06-13'),
(25,'David Smith','Facilities Manager','Operations','d.smith@medirozahospital.com','+27 82 125 2175','85021253275087',52000,'2014-01-27'),
(26,'Karen O'Connor','Billing Administrator','Finance','k.oconnor@medirozahospital.com','+27 82 126 2182','85031263286088',29000,'2018-03-19'),
(27,'James Wilson','Security Supervisor','Operations','j.wilson@medirozahospital.com','+27 82 127 2189','85041273297089',27000,'2019-09-02'),
(28,'Linda Fourie','Receptionist','Front Office','l.fourie@medirozahospital.com','+27 82 128 2196','85051283308081',19000,'2020-02-10'),
(29,'Peter van Wyk','Procurement Officer','Supply Chain','p.wyk@medirozahospital.com','+27 82 129 2203','85061293319082',38000,'2015-08-24'),
(30,'Andile Mbeki','Ward Clerk','Administration','a.mbeki@medirozahospital.com','+27 82 130 2210','85071303330083',21000,'2019-11-05');
UNLOCK TABLES;
```

Screenshot of the SQL file showing staff details, including salaries.

b. Shareholder details:

ID	Shareholder Name	Share Percent (%)	Shares Held	Share Class
1	Dr. Rajesh Naidoo	18.0	180,000	Ordinary
2	Cedar Health Holdings (Pty) Ltd	15.0	150,000	Ordinary
3	Dr. Johan van der Merwe	12.0	120,000	Ordinary
4	Reddy Family Trust	11.0	110,000	Ordinary
5	Thabo Molefe	10.0	100,000	Ordinary
6	Sarah Botha	9.0	90,000	Ordinary
7	Dr. Ahmed Kara	8.0	80,000	Preferential
8	Naledi Zulu	7.0	70,000	Ordinary
9	Michael Roberts	6.0	60,000	Ordinary
10	Dr. Vikram Chetty	4.0	40,000	Preferential

```
LOCK TABLES `shareholders` WRITE;
INSERT INTO `shareholders`
(`id`,`shareholder_name`,`share_percent`,`shares_held`,`share_class`) VALUES
(1,'Dr. Rajesh Naidoo',18.0,180000,'Ordinary'),
(2,'Cedar Health Holdings (Pty) Ltd',15.0,150000,'Ordinary'),
(3,'Dr. Johan van der Merwe',12.0,120000,'Ordinary'),
(4,'Reddy Family Trust',11.0,110000,'Ordinary'),
(5,'Thabo Molefe',10.0,100000,'Ordinary'),
(6,'Sarah Botha',9.0,90000,'Ordinary'),
(7,'Dr. Ahmed Kara',8.0,80000,'Preferential'),
(8,'Naledi Zulu',7.0,70000,'Ordinary'),
(9,'Michael Roberts',6.0,60000,'Ordinary'),
(10,'Dr. Vikram Chetty',4.0,40000,'Preferential');
UNLOCK TABLES;
```

Screenshot of the SQL file showing shareholder details.

Risk Rating

#	Risk / Finding	Evidence / Observation	Potential Impact	Risk Level
1	Back-end architectural data exposed	Wrong and correct username guessing revealed account enumeration	Attackers may exploit the back-end	High
2	Unsecure ports open	Ports with corresponding unencrypted protocols appear open	Provides exploitable entry points on the web server	Medium
3	User authentication flaw exposed	Improper input validation, where login submission with empty password box was permitted	May ease brute-forcing attacks	High
4	SQL misconfiguration	SQL injection test returned a visible database error message	Vulnerability to SQL injection attacks	High
5	Restricted and sensitive records unprotected	Instructions for external crawlers revealed hidden but unprotected paths	Attackers may infiltrate the directories and steal exposed sensitive data	High

Recommendations and Remediation

In response to existing risks and vulnerabilities, the following remediations are recommended.:

1. Only the ports for encryption-secured protocols should be open.
2. Web frontend and backend should be configured with input validation and input sanitation.
3. Implement alternatives to a robots.txt file which don't enumerate hidden/restricted paths. Examples include adding a **X-Robots-Tag** in the HTTP response header, or adding a HTML Meta Tag to the specific page/path you want restricted.
4. Private/hidden directories and retained database files should be encrypted.
5. Implement unified login response messages to obscure SQL errors from potential attackers.
6. Encrypt sensitive files on the file server.